Throughout, ACME's experience will demonstrate a key lesson: Zero Trust isn't a product you buy, but is instead an architectural shift that naturally occurs when identity, policy, and context become the main tools of security.

NOTE

This chapter explains how authorization provides a foundation for implementing zero trust, but before that can occur, your organization needs a solid handle on authentication. Review chapters 2 and 3 to understand why this is necessary and see what you might be missing.

15.1 Rethinking security for the Zero Trust era

Sam had spent most of his career defending a perimeter. Firewalls, network segmentation, and VPN gateways were the tools he had relied on to keep ACME's internal systems secure. For years, the strategy seemed sound: Draw a clear boundary around critical resources, funnel remote workers through a VPN. Everything outside the perimeter was untrusted, and everything within was trusted implicitly. But by the time the board began pushing for a Zero Trust strategy, Sam already sensed the uncomfortable truth: ACME's environment no longer had a true perimeter.

Figure 15.1 clearly illustrates the problem. The old security model relied on a crisp boundary between trusted internal networks and the untrusted outside world. When someone crossed that boundary—by joining the corporate network or connecting through the VPN—their traffic and access requests were implicitly trusted. Lateral movement was easy because everything inside the perimeter was considered part of the same zone of trust.